

Anleitung: Widerrufsfunktion einbauen (Verzeichnis Widerrufs_Formular)

Stand 06.10.2026, Fassung 2 (Schutz vor Missbrauch, Anhang A). Rechtsgrundlage: § 356a BGB (Pflicht seit 19.06.2026). Hintergrund: Analyse_Widerruf_Kuendigung.pdf, Programmierliste_Widerruf_Kuendigung.pdf (Punkte W1-W8).

1. Inhalt des Verzeichnisses

Datei	Zweck
vertrag-widerrufen.html	Formularseite „Vertrag widerrufen“ (Deutsch). Enthält nur den Inhaltsbereich; Kopf- und Fußzeile kommen aus der Seitenvorlage.
widerruf.php	Auswertung (PHP 8): prüft Eingaben, prüft auf Missbrauch (Anhang A), vergibt Vorgangsnummer mit Zeitstempel, schreibt Protokoll, sendet Eingangsbestätigung an den Kunden und Meldung an die Bearbeiter der Member-Mails, zeigt Bestätigungsseite.
Anleitung_Widerruf.md / .pdf	diese Anleitung

2. Seite einbauen

- Seite unter einer festen Adresse veröffentlichen, z. B.
<https://www.weatheronline.co.uk/vertrag-widerrufen>. **Ohne Anmeldung** erreichbar.
- In die Seitenvorlage übernehmen: den Inhalt von `<main>...</main>` und den `<style>`-Block (ggf. an das Design anpassen). Den einfachen `<header>` der Datei durch den Kopf der Webseite ersetzen; die Fußzeile kommt dynamisch aus der Vorlage.
- `<meta name="robots" content="noindex">` beibehalten.
- Keine externen Ressourcen einbinden (keine fremden Schriften, Skripte, Tracking, Werbung) – die Seite verarbeitet personenbezogene Daten.
- Platzhalter ersetzen:
- `[Link zur Widerrufsbelehrung]`
- `[Link zur Datenschutzerklärung]`
- Feldnamen nicht ändern (`name`, `vertrag`, `produkt`, `email`, `mitteilung`, `website`, `dauer`); `widerruf.php` liest genau diese. `website` ist eine unsichtbare Falle für automatische Eingaben, `dauer` wird vom kleinen Skript am Seitenende gefüllt (Anhang A). Das Skript inline lassen (keine externe Datei nötig).
- Beschriftung der Schaltfläche „**Widerruf bestätigen**“ nicht ändern (gesetzlich vorgegeben).

3. Link „Vertrag widerrufen“ in der Fußzeile (dynamisch)

- In der Fußzeile **jeder Seite** von www.weatheronline.co.uk, member.weatheronline.co.uk (aMember) und dpds.weatheronline.co.uk.
- Farblich hervorgehoben** gegenüber den übrigen Fußzeilen-Links (z. B. rot und fett).
- Zusätzlich im Kontomenü des Mitgliederbereichs.
- Ziel: die Adresse aus 2.1.
- Daneben später „Verträge hier kündigen“ (eigene Seite, folgt).

4. widerruf.php einrichten

- In dasselbe Verzeichnis wie die Formularseite legen oder `action="widerruf.php"` im Formular auf den tatsächlichen Pfad setzen.
- Einstellungen am Dateianfang prüfen:

3. `MEMBER_MAIL` = member@weatheronline.co.uk (Empfänger der internen Meldung)
4. `ABSENDER` = Absender der E-Mails; Domain muss für den Server per SPF/DKIM zugelassen sein, sonst landen Bestätigungen im Spam.
5. `DATENVERZ` = Verzeichnis für Protokoll (`widerrufe.csv`) und Zählerdatei (`zaehler.json`).
Außerhalb des Web-Verzeichnisses; für den Webserver beschreibbar, nicht öffentlich abrufbar.
6. `IP_SALZ` = einmalig einen geheimen Zufallswert eintragen (z. B. `php -r 'echo bin2hex(random_bytes(16));'`).
7. `HINTER_CLOUDFLARE` = `true` nur, wenn der Server ausschließlich über Cloudflare erreichbar ist (sonst kann die IP-Angabe gefälscht werden); andernfalls `false`.
8. Grenzwerte `MAX_JE_IP` (3), `FENSTER_SEK` (3600), `ALARM_GESAMT` (20), `MIN_DAUER_MS` (3000) – nur bei Bedarf ändern.
9. Zeitzone `Europe/London` (Zeitstempel in BST/GMT); bei Bedarf `Europe/Berlin`.
10. E-Mail-Versand: Das Skript nutzt `mail()`. Ist auf dem Server kein lokaler Mailversand eingerichtet, auf eine SMTP-Bibliothek (z. B. PHPMailer) umstellen – Funktion `sende()`.
11. HTTPS erzwingen; Header `X-Powered-By` abschalten (`expose_php = off`), HSTS setzen.

5. Testen (vor Freischaltung)

Test	Erwartung
Formular mit allen Pflichtfeldern absenden	Bestätigungsseite mit Datum, Uhrzeit, Vorgangsnummer; E-Mail an Kunde und Bearbeiter der Member-Mails; Zeile in der CSV-Datei
Pflichtfeld leer oder E-Mail ungültig	Fehlerseite (HTTP 422) mit Hinweisen; nichts versandt, nichts protokolliert
Feld <code>website</code> ausgefüllt	Seite „Vielen Dank“, nichts versandt, nichts protokolliert
Absenden schneller als 3 Sekunden (<code>dauer < 3000</code>)	Bestätigungsseite; keine Kunden-E-Mail; Meldung „[PRÜFEN]“ an die Bearbeiter der Member-Mails; Protokoll „auffaellig“
4. Absendung von derselben IP-Adresse innerhalb 60 Minuten	wie vorige Zeile
Mitteilung mit Link (<code>https://... , www....</code>)	Kunden-E-Mail mit „[Link entfernt]“; Bearbeiter der Member-Mails erhalten Originaltext
Name beginnt mit <code>=</code>	in der CSV mit vorangestelltem <code>'</code> gespeichert
20 Absendungen insgesamt in 60 Minuten	einmalige Alarm-E-Mail an die Bearbeiter der Member-Mails
Umlaute und Sonderzeichen	korrekt in E-Mail-Betreff, E-Mail-Text und CSV
Zeilenumbruch in Name/E-Mail-Feld	wird entfernt (kein Einschleusen von E-Mail-Kopfzeilen)
Aufruf von <code>widerruf.php</code> per GET	Weiterleitung auf die Formularseite
CSV-Datei per Browser aufrufen	nicht erreichbar
Link in der Fußzeile	auf allen drei Domains sichtbar, hervorgehoben, ohne Anmeldung nutzbar

6. Bearbeitung eingegangener Widerrufe (Bearbeiter der Member-Mails)

Pro Meldung, spätestens innerhalb von 14 Tagen:

1. Vertrag in aMember bzw. Datenbestellung anhand von Benutzername oder Rechnungsnummer suchen. **Angegebene E-Mail-Adresse mit der im Konto vergleichen** – weicht sie ab, vor

Sperre und Erstattung über die Konto-E-Mail-Adresse nachfragen (Schutz gegen Widerruf durch Dritte).

2. Meldungen mit „[PRÜFEN]“: Kunde hat **keine** automatische Bestätigung erhalten. Ist es ein echter Widerruf, Eingangsbestätigung von Hand an die Konto-E-Mail-Adresse senden (mit Datum und Uhrzeit des Eingangs aus der Meldung).
3. Alarm-E-Mail: Protokoll durchsehen; bei Angriff zusätzlich Cloudflare-Begrenzung aktivieren (Anhang A, offener Punkt O1).
4. Prüfen, ob das Widerrufsrecht noch besteht (Vertragsschluss höchstens 14 Tage vor Eingang; Checkbox zum sofortigen Beginn und Vertragsbestätigung vorhanden?).
5. Besteht es: Zugang sperren, **PayPal-Abonnement im PayPal-Händlerkonto beenden**, Erstattung in aMember bzw. bei PayPal/Mollie auslösen.
6. Besteht es nicht: Kunden informieren; ggf. als Kündigung zum Laufzeitende behandeln.
7. Erledigung in der CSV-Datei oder im Ticketsystem vermerken.

7. Datenschutz und Aufbewahrung

- Protokoll und E-Mails dienen als Nachweis; Aufbewahrung 3 Jahre ab Jahresende (EU) bzw. 6 Jahre (UK), danach löschen.
- Zählerdatei: speichert nur einen gekürzten, gesalzenen Hash der IP-Adresse; Einträge werden nach 60 Minuten automatisch gelöscht (Anhang A.4).
- Datenschutzerklärung um Abschnitt 3.3.5 „Widerruf und Kündigung“ ergänzen (Text in der Analyse, Anhang A.8).
- Server- und Mail-Dienstleister müssen als Auftragsverarbeiter erfasst sein (Verzeichnis der Verarbeitungstätigkeiten).

8. Später anzupassen

- Text der Eingangsbestätigung, sobald die Einordnung der Mitgliedschaft feststeht: bei „digitaler Dienstleistung“ Erstattung „abzüglich eines anteiligen Betrags für die bis zum Widerruf genutzte Zeit“ (`widerruf.php`, Variable `$textKunde`; Infokasten der HTML-Seite).
- Englische Fassung (Vereinigtes Königreich), wenn gewünscht.
- Seite „Verträge hier kündigen“ nach demselben Muster (Programmierliste K1-K8).

Anhang A: Schutz vor Missbrauch - Analyse und Stand (06.10.2026)

A.1 Ausgangslage

Die Widerrufsfunktion muss nach § 356a BGB **ohne Anmeldung, leicht zugänglich und ständig verfügbar** sein. Der Widerruf gilt mit dem Absenden als erklärt; eine Eingangsbestätigung ist sofort per E-Mail zu senden. Daraus folgt: Schutzmaßnahmen dürfen einen echten Widerruf weder verhindern noch verzögern. Ungeeignet sind Anmeldung, CAPTCHA (zusätzliche Hürde und Fremdskripte) und Bestätigungslinks vor dem Eingang. Geeignet sind unsichtbare Maßnahmen, die **niemals einen Widerruf verwerfen**, sondern nur die automatische Kunden-E-Mail zurückhalten und den Vorgang zur Prüfung an die Bearbeiter der Member-Mails geben.

A.2 Gefährdungen

Nr.	Gefährdung	Folge ohne Schutz
G1	Missbrauch als E-Mail-Versender: fremde Adresse eintragen, Werbung oder betrügerische Links in „Mitteilung“ – die Eingangsbestätigung trägt den Text an Dritte, beliebig oft	Spam unter dem Namen WeatherOnline; Sperrung der Absender-Domain durch E-Mail-Anbieter
G2	Widerruf durch Dritte mit bekanntem Benutzernamen	Sperre und Erstattung gegen den Willen des Mitglieds

Nr.	Gefährdung	Folge ohne Schutz
G3	Formel-Einschleusung in die CSV-Datei (=HYPERLINK(...))	Ausführung beim Öffnen in Excel o. Ä.
G4	Massenhafte automatische Absendungen (Bots)	Flut von E-Mails und Protokolleinträgen
G5	Einschleusen von E-Mail-Kopfzeilen über Formularfelder	Versand an beliebige Empfänger
G6	Einschleusen von HTML/Skripten in die Bestätigungsseite	Ausführung fremder Skripte im Browser des Nutzers
G7	Absenden von fremden Webseiten aus (CSRF)	Widerrufe im Namen ahnungsloser Besucher
G8	Gefälschte E-Mails im Namen von WeatherOnline	Täuschung von Kunden

A.3 Umgesetzte Maßnahmen

Nr.	Maßnahme	Umsetzung (widerruf.php bzw. HTML)	gegen	Testergebnis 06.10.2026
M0	Fallenfeld	unsichtbares Feld website ; ausgefüllt → Seite „Vielen Dank“, nichts gespeichert, nichts versandt	G4	✓
M0	Nur POST, Pflichtfelder, gültige E-Mail, Längenbegrenzung	GET → Umleitung; Fehler → HTTP 422 ohne Versand	G4	✓
M0	Kopfzeilen-Schutz	Zeilenumbrüche in einzeiligen Feldern entfernt; Empfänger und Absender fest	G5	✓
M0	Ausgabe maskiert, Sicherheits-Header	htmlspecialchars ; Content-Security-Policy (keine Skripte), X-Content-Type-Options: nosniff, frame-ancestors 'none' auf der Bestätigungsseite	G6	✓
M1(a)	Begrenzung je IP-Adresse	höchstens 3 Absendungen je IP-Adresse in 60 Minuten; ab der 4.: Vorgang wird gespeichert und an die Bearbeiter der Member-Mails gemeldet („[PRÜFEN]“), keine Kunden-E-Mail; Bestätigungsseite mit Hinweis	G1, G4	✓ (4. und 5. Absendung ohne Kunden-E-Mail)
M1(b)	Links entfernen	in der Kunden-E-Mail werden Links in „Mitteilung“ durch „[Link entfernt]“ ersetzt; Bearbeiter der Member-Mails erhalten den Originaltext	G1	✓
M1(c)	Alarm	ab 20 Absendungen insgesamt in 60 Minuten eine Alarm-E-Mail an die Bearbeiter der Member-Mails, höchstens einmal je Stunde	G1, G4	✓ (genau ein Alarm bei 22 Absendungen)
M2	Prüfung durch die Bearbeiter der Member-Mails	interne Meldung enthält Arbeitsschritt „E-Mail-Adresse mit Konto vergleichen, bei Abweichung über Konto-Adresse nachfragen“; Kunden-E-Mail enthält „Falls Sie diesen Widerruf nicht selbst abgesendet haben, antworten Sie bitte“; Erstattung nur an das ursprüngliche Zahlungsmittel	G2	organisatorisch (Abschnitt 6)
M3	CSV-Schutz	Werte, die mit = , + , - , @ beginnen, werden mit ' gespeichert	G3	✓

Nr.	Maßnahme	Umsetzung (widerruf.php bzw. HTML)	gegen	Testergebnis 06.10.2026
M4	Mindestzeit	Skript in der Seite misst die Zeit bis zum Absenden (dauer); unter 3 Sekunden → wie M1(a); ohne JavaScript wird nicht bewertet	G4	✓ (500 ms → keine Kunden-E-Mail)

A.4 Datenschutz der Schutzmaßnahmen

- Gespeichert wird **keine IP-Adresse im Klartext**, sondern ein auf 16 Zeichen gekürzter SHA-256-Wert der IP-Adresse mit geheimem Salz (IP_SALZ); Einträge werden nach 60 Minuten automatisch gelöscht.
- Zweck: Schutz der Funktion vor Missbrauch; Rechtsgrundlage berechtigtes Interesse (Art. 6 Abs. 1 lit. f DSGVO bzw. UK GDPR).
- Ergänzung für den vorgeschlagenen Abschnitt 3.3.5 der Datenschutzerklärung (Analyse, Anhang A.8): „Zum Schutz vor Missbrauch wird die IP-Adresse kurzzeitig in gekürzter, verschlüsselter Form (Hashwert) gespeichert und nach 60 Minuten gelöscht.“

A.5 Was erreicht ist

- Ein echter Widerruf wird in jedem Fall **gespeichert, an die Bearbeiter der Member-Mails gemeldet und auf der Seite mit Datum und Uhrzeit bestätigt** – auch bei Verdacht auf Missbrauch.
- Der Versand von Werbung über die Eingangsbestätigung ist auf höchstens 3 E-Mails je IP-Adresse und Stunde begrenzt und enthält keine anklickbaren Links.
- Automatische Massenabsendungen werden erkannt (Fallenfeld, Mindestzeit, Begrenzung) und gemeldet; ein Angriff löst einen Alarm aus.
- Kopfzeilen-, HTML- und Formel-Einschleusung sind unterbunden.
- Keine Hürde für Verbraucher: keine Anmeldung, kein CAPTCHA, keine Fremdskripte.

A.6 Was offen ist

Nr.	Offener Punkt	Bewertung / Vorschlag	Zuständig
O1	Verteilte Angriffe über viele IP-Adressen: je IP bis zu 3 Kunden-E-Mails möglich	Restrisiko; Alarm (M1(c)) erkennt es. Zusätzlich Begrenzungsregel in Cloudflare für den Pfad widerruf.php (z. B. 10 Anfragen je Minute und IP) und ggf. „Bot Fight Mode“ ohne sichtbare Abfrage	Server / Cloudflare
O2	Gemeinsame IP-Adressen (Firmennetz, Mobilfunk): echte Kunden können als „auffällig“ gelten	keine automatische Bestätigung → Bearbeiter der Member-Mails müssen „[PRÜFEN]“-Meldungen am selben Tag bearbeiten und die Bestätigung von Hand senden; Rechtsrisiko gering, solange das geschieht	Bearbeiter der Member-Mails
O3	Link-Erkennung ist eine Liste üblicher Muster; verschleierte Adressen (z. B. „spam punkt de“) werden nicht erkannt	Restrisiko gering, da nicht anklickbar	–
O4	Ohne JavaScript entfällt die Zeitprüfung (M4)	gewollt (keine Benachteiligung); übrige Maßnahmen greifen	–
O5	CSRF-Token (G7) nicht umgesetzt	geringes Risiko, da Widerruf ohnehin ohne Anmeldung möglich und jeder Eingang geprüft wird; optional später	Programmierung
O6	SPF, DKIM, DMARC für die Absender-Domain (G8)	vor dem Einsatz einrichten, sonst landen Bestätigungen im Spam	Server / E-Mail

Nr.	Offener Punkt	Bewertung / Vorschlag	Zuständig
O7	HINTER_CLOUDFLARE : Bei direkter Erreichbarkeit des Servers ist CF-Connecting-IP fälschbar	Server nur über Cloudflare erreichbar machen oder Einstellung auf false	Server
O8	IP_SALZ ist ein Platzhalter	vor dem Einsatz ersetzen	Programmierung
O9	Datenschutzerklärung	Satz aus A.4 in Abschnitt 3.3.5 übernehmen	Datenschutz
O10	Gleiches Schutzkonzept für die spätere Seite „Verträge hier kündigen“	übernehmen	Programmierung